

Lexique soutenance CDA — zØmbie zØne

Termes généraux (base)

Terme	Définition
Gestion de version	Système (Git) qui enregistre les modifications du code au fil du temps. Permet de collaborer, revenir en arrière, conserver un historique.
Tests automatisés	Outils logiciels qui exécutent des tests sur le code automatiquement — unitaires, intégration — pour vérifier qu'il fonctionne et éviter les régressions.
Front-end vs Back-end	Front-end = partie visible (React, HTML/CSS/JS côté navigateur). Back-end = partie logique invisible (Express, BDD, API).
Back-office	Interface d'administration réservée aux gestionnaires. Dans le projet : /manage accessible uniquement aux admins via requireRole .
IDE	Environnement de développement intégré. VS Code dans le projet.
Dépendance	Bibliothèque externe dont le projet a besoin (installée via npm). Ex : argon2, prisma, zod.
Token	Jeton numérique (chaîne de caractères) servant à identifier un utilisateur après authentification. Dans le projet : JWT access token + refresh token.
JSON	Format d'échange de données clé/valeur. Toutes les réponses de l'API retournent du JSON.
Client vs Serveur	Client = navigateur qui envoie la requête. Serveur = Express qui reçoit, traite et répond.
Callback	Fonction passée en argument d'une autre fonction, exécutée après une tâche.
Handler	Fonction déclenchée en réponse à une action (clic, soumission de formulaire, événement).
Scope	Zone d'un programme où une variable est accessible.
DOM	Représentation en arbre d'une page web que JavaScript peut manipuler dynamiquement.
Responsive / Mobile-first	Le site s'adapte à toutes les tailles d'écran. Dans le projet : conçu d'abord pour mobile, étendu au desktop.
CRUD	Create, Read, Update, Delete — les 4 opérations fondamentales sur les données.
API REST	Interface de communication entre applications via HTTP, utilisant GET/POST/PUT/DELETE sur des URLs claires.
ORM	Object-Relational Mapping — manipule la BDD via des objets JS plutôt qu'en SQL brut. Dans le projet : Prisma.
SGBD	Système de Gestion de Base de Données. Dans le projet : PostgreSQL 16.
Clé primaire / étrangère	Clé primaire = identifiant unique d'une ligne. Clé étrangère = champ qui pointe vers la clé primaire d'une autre table (relation).
MVC	Modèle-Vue-Contrôleur. Séparation des responsabilités : données / interface / logique métier.
Design pattern	Solution standardisée à un problème récurrent d'architecture.
POO	Programmation Orientée Objet — regrouper données et comportements dans des objets.

Terme	Définition
Déploiement	Transfert du code depuis le développement local vers un serveur de production accessible aux utilisateurs.
OWASP	Communauté qui publie le Top 10 des failles de sécurité web les plus critiques.
Headers HTTP	En-têtes envoyés avec chaque requête/réponse. Métadonnées : type de contenu, auth, cache, sécurité.
GET vs POST	GET = récupérer des données (paramètres dans l'URL). POST = envoyer des données (dans le body, masquées).
SCRUM	Cadre de travail agile basé sur des cycles courts (sprints). Dans le projet : adapté au contexte solo.

Termes spécifiques au projet

Terme	Définition dans le contexte zØmbie zØne
Middleware	Fonction intercalée entre la requête HTTP et le controller. <code>requireAuth</code> vérifie le JWT, <code>requireRole</code> vérifie le rôle, <code>Zod</code> valide le body. Si une vérification échoue, la requête est bloquée avant d'atteindre le controller.
Payload JWT	Partie "données" encodée dans le JWT. Access token : <code>{ id, role }</code> . Refresh token : <code>{ userId, tokenId }</code> . Encodé en base64, pas chiffré — mais signé, donc infalsifiable sans le secret.
Token rotation	À chaque <code>/refresh</code> , l'ancien refresh token est supprimé en base et remplacé par un nouveau. Si un token volé est utilisé après que le client légitime l'a rotaté, il est rejeté — <code>token_id</code> absent en base.
Soft delete	Suppression logique : <code>deleted_at = now()</code> . La ligne reste en base mais est filtrée dans les requêtes. Dans le projet : <code>users</code> et <code>orders</code> uniquement, pour la traçabilité RGPD.
Hard delete	Suppression physique de la ligne en base. Dans le projet : <code>activities</code> , <code>sessions</code> , <code>categories</code> — intentionnel pour libérer les fichiers images associés.
Race condition	Deux opérations concurrentes qui se marchent dessus. Dans le projet : deux appels simultanés à <code>/refresh</code> (React StrictMode) consomment le même token. Solution : Promise singleton <code>refreshPromise</code> .
Atomic transaction	Bloc d'opérations qui s'exécutent ensemble ou pas du tout. Dans le projet : <code>\$transaction</code> Prisma pour vérification de capacité + création de ligne de commande. Si la capacité est insuffisante, rien n'est inséré.
Reverse proxy	Serveur intermédiaire qui reçoit les requêtes et les redirige. Dans le projet : <code>Nginx</code> reçoit tout, redirige <code>/api/</code> vers le backend Node (réseau Docker interne), sert le frontend en statique.
Ephemeral service	Service qui existe temporairement. Dans le CI GitHub Actions : le container PostgreSQL de test est créé au début du pipeline et détruit à la fin. Ne persiste pas entre les runs.
RBAC	Role-Based Access Control. Les permissions sont attachées au rôle, pas à l'utilisateur directement. User a un rôle (<code>member</code> ou <code>admin</code>), le middleware <code>requireRole</code> vérifie ce rôle.
httpOnly cookie	Cookie inaccessible à JavaScript (<code>document.cookie</code>). Protège contre le vol de token par XSS. Les JWT du projet sont exclusivement en httpOnly.
SameSite=Strict	Le cookie n'est pas envoyé depuis un domaine tiers. Protection native contre le CSRF.

Terme	Définition dans le contexte zØmbie zØne
argon2id	Algorithme de hachage des mots de passe résistant aux attaques GPU — gourmand en mémoire, pas seulement en temps de calcul. Recommandé OWASP 2023, supérieur à bcrypt.
Requêtes paramétrées	La valeur est transmise séparément de la chaîne SQL — jamais concaténée dedans. Prisma génère toujours des requêtes paramétrées : injection SQL structurellement impossible.
Definition of Done	Liste de critères qu'une tâche doit remplir pour être considérée terminée. Dans le projet : lint Biome propre + tests qui passent + PR mergée + CI verte.
bfcache	Back/forward cache : le navigateur gèle une page en mémoire et la restaure sur "Précédent" sans ré-exécuter le JS. Solution : Cache-Control: no-store + vérification réseau au montage de chaque page protégée.
Code splitting	Vite découpe le JS en plusieurs chunks au build. Le navigateur ne télécharge que le JS nécessaire à la page affichée.
Multi-stage Docker	Dockerfile avec deux étapes : builder compile TypeScript → runner ne contient que le dist/ compilé et les dépendances de prod. Image finale allégée, sans sources TypeScript ni devDependencies.
select explicite Prisma	On déclare exactement les colonnes retournées. password_hash n'est jamais retourné par accident dans une réponse API.
Prix figés (orders_lines)	unit_price_ht et vat_rate sont copiés à la création de la ligne. Si le prix d'une activité change après, les commandes historiques restent intactes.
token_id UUID	Identifiant unique du refresh token stocké en base. Lookup direct par index — la recherche est immédiate quelle que soit la taille de la table. En base : token_id en clair + hash argon2 du token_id.
Symlink migrations	Prisma cherche les migrations dans prisma/migrations relatif au CWD. Notre schéma est dans backend/src/models/migrations . Résolution : symlink créé dans le Dockerfile.
Headers de sécurité HTTP	Ajoutés dans nginx.conf : X-Frame-Options: DENY , X-Content-Type-Options: nosniff , Strict-Transport-Security , Referrer-Policy . Pas besoin de Helmet — ce sont de simples directives Nginx.
request.agent (Supertest)	Maintient les cookies entre les requêtes dans les tests, comme un vrai navigateur. Nécessaire pour tester les routes protégées après un login.
Tests sans effet de bord	Un test ne laisse pas de trace qui affecte le test suivant. resetDatabase() vide toutes les tables avant chaque suite — chaque test repart d'une base vierge.
user_id depuis JWT	Le user_id est toujours extrait de req.user.id (payload JWT vérifié). Jamais du body. Empêche un utilisateur de créer des ressources au nom d'un autre.